

安全漏洞审计报告 · 第9轮

用户信息管理平台

XXE 外部实体注入漏洞审计报告

User Management Platform — XML External Entity Injection Assessment

目标系统：用户信息管理平台 (Flask)

报告日期：2026-07-17

漏洞等级：严重 × 2

修复状态：✅ 全部已修复

目录

1. 报告概述
2. 漏洞详情
3. 攻击演示
4. 修复方案
5. 修复前后对照
6. 修复验证
7. 全部九轮汇总

1. 报告概述

1.1 本轮背景

系统新增了**XML** 数据导入功能（/xml-import），该功能检测 XML 中的 `<!ENTITY ... SYSTEM>` 定义，提取文件路径并用 `open()` 读取本地文件内容后替换实体引用。这完全复现了经典的 **XXE (XML External Entity)** 漏洞，攻击者可通过 `file:///etc/passwd` 读取任意服务器文件。

1.2 什么是 XXE？

XXE (XML External Entity) 攻击者在 XML 中定义外部实体，指向服务器上的本地文件。当 XML 解析器处理实体引用时，文件内容被读取并返回给攻击者。这是 OWASP Top 10 常见漏洞之一。

2. 漏洞详情

2

● 严重漏洞

2/2

✓ 已修复

VULN-27 : XXE 读取任意文件

● 严重

位置 : /xml-import — POST 路由

漏洞代码 :

```
// 手动检测 ENTITY + SYSTEM → 提取路径 → open() 读取 → 返回给用户
entity_match = re.search(r', xml_data)
file_path = entity_match.group(1)
file_content = open(file_path, "r").read()
// 将文件内容替换掉 &xxe; 后解析 XML
replaced_xml = re.sub(f'&{entity_name};', file_content, xml_data)
```

描述 : 代码检测到 `<!ENTITY xxe SYSTEM "file:///etc/passwd">` 后, 提取路径 `/etc/passwd`, 直接 `open()` 读取文件内容, 然后替换掉 `&xxe;` 引用, 最终包含在解析结果中返回给用户。

VULN-28 : 敏感文件泄露

● 严重

可利用的读取目标 :

- /etc/passwd — 系统用户列表 ✓ 已确认读取成功
- /etc/shadow — 系统密码哈希 ✓ 已确认可读取
- app.py — Flask 源码 ✓ 已确认可读取
- .git/config — Git 仓库配置
- data/users.db — SQLite 数据库文件

3. 攻击演示

3.1 XXE Payload 读取 /etc/passwd

📌 攻击请求 (**POST /xml-import**)

```
<?xml version='1.0'?>
<!DOCTYPE foo [<!ENTITY xxe SYSTEM 'file:///etc/passwd'>]>
<users><user><name>&xxe;</name></user></users>
```

👁️ 攻击结果

```
root:x:0:0:root:/root:/usr/bin/zsh
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
✅ /etc/passwd 内容已泄露 !
```

3.2 其他可读取的文件

📌 其他攻击 **Payload**

```
file:///etc/shadow      → root:$y$j9T$... (密码哈希) ✅
file:///app.py          → from flask import... (源码) ✅
file:///home/*/.ssh/id_rsa → SSH 私钥
```

4. 修复方案

4.1 移除 ENTITY/SYSTEM 检测逻辑

```
// 删掉检测 ENTITY/SYSTEM 并 open() 读取文件的代码
entity_match = re.search(r'
file_content = open(file_path).read() ← 删除
```

4.2 清洗 XML 后再解析

```
// 1. 移除 DOCTYPE 声明
cleaned_xml = re.sub(r']*>', '', xml_data)

// 2. 移除实体引用
cleaned_xml = re.sub(r'&\w+;', '', cleaned_xml)

// 3. 用 ElementTree 安全解析 (默认不解析外部实体)
root = ET.fromstring(cleaned_xml)
```

5. 修复前后对照

✖ 修复前

re.search ENTITY+SYSTEM → 提取路径
open(path).read() → 读取任意文件
替换 &xxe; → 返回文件内容

→ file:///etc/passwd ✔ 可读取

✔ 修复后

re.sub DOCTYPE → 删除声明
re.sub &实体; → 清理引用
ET.fromstring → 安全解析

→ file:///etc/passwd ❌ 被拦截

6. 修复验证

#	测试	结果
1	正常 XML 解析 → 成功	✓ 通过
2	XXE file:///etc/passwd → 被拦截	✓ 通过
3	XXE file://app.py → 被拦截	✓ 通过
4	未登录访问 → 跳转	✓ 通过

7. 全部九轮汇总

轮次	审计内容	漏洞数	严重	高危	中危	状态
第 1 轮	密码安全	8	4	-	4	✓
第 2 轮	SQL 注入	2	2	-	-	✓
第 3 轮	文件上传	1	1	-	-	✓
第 4 轮	业务逻辑	7	2	2	3	✓
第 5 轮	文件包含	2	2	-	-	✓
第 6 轮	CSRF	2	1	1	-	✓
第 7 轮	SSRF	2	2	-	-	✓
第 8 轮	命令注入	2	2	-	-	✓
第 9 轮	XXE	2	2	-	-	✓
合计		28	18	3	7	全部已修复

安全漏洞审计报告 · 第9轮 — XXE 安全 | 报告日期：2026-07-17

项目地址：<https://github.com/sencly-book/user-management>